

SISTEMA GUARDIÃO — RELATÓRIO DE SEGURANÇA E PENTEST

Análise Técnica de Vulnerabilidades, Defesas em Profundidade e Conformidade

STATUS GERAL DE SEGURANÇA: NÍVEL ELEVADO (PRONTO PARA PENTEST)

Ambiente em produção com defesas ativas: Autenticação Segura (Bcrypt), Proteção contra Brute Force, Row Level Security (RLS) em 100% das tabelas e isolamento por Organização Militar (OM).

1. Informações da Auditoria e Escopo

- Aplicação: Guardião (GSD-SP - Gestão de Operações e Acessos)
- Ambiente Auditado: Produção Ativa (Multi-Tenant Multi-OM)
- Banco de Dados: PostgreSQL 15+ gerenciado via Supabase
- Usuários Protegidos: 696 militares cadastrados
- Data de Aplicação das Correções: 07 de Setembro de 2026
- Objetivo: Neutralização dos vetores de ataque mapeados na preparação para Pentest.

2. Matriz de Vulnerabilidades: Situação Pré vs Pós-Hardening

Vetor de Ataque / Teste	Classificação Pré	Medida Implementada	Status Atual
Vazamento de Senhas (PlainText)	CRÍTICO (Alto Risco)	Trigger Bcrypt + RPC secure_login	NEUTRALIZADO
Ataque de Força Bruta (Login)	ALTO (Sem Limite)	Rate limit (5 falhas / 15 min lock)	PROTEGIDO
Exposição de Senha em Memória	MÉDIO (Exposto no state)	Sanitização de state e RPC blind	CONFORME
Bypass de RLS / Escuta Pública	MÉDIO (Acessos abertos)	RLS habilitado em 30 tabelas	MITIGADO
Escalada de Privilégio (Admin)	ALTO (Edição indevida)	canManageUser + canAssignFunction	BLINDADO

3. Detalhamento Técnico das Medidas de Segurança

3.1. Hashing Criptográfico em Nível de Banco (Bcrypt / Blowfish)

A extensão nativa pgcrypto do PostgreSQL foi integrada ao schema público com um trigger automático (trg_hash_user_password). Qualquer operação de INSERT ou UPDATE na coluna password é interceptada: se a senha não contiver a assinatura de hash Bcrypt (\$2a\$, \$2b\$ ou \$2y\$), ela é convertida imediatamente usando crypt(password, gen_salt('bf', 10)). Isso impede o armazenamento inadvertido de credenciais em texto claro, tanto via interface web, scripts de importação ou chamadas de reset administrativo.

3.2. Mecanismo de Autenticação Segura (Stored Procedure RPC secure_login)

O fluxo de autenticação foi migrado de consultas diretas com filtro na tabela (select * where password=...) para a execução de uma Stored Procedure encapsulada (public.secure_login).

Benefícios técnicos:

- Zero Exposição do Hash: O frontend não recebe o hash da senha em nenhuma hipótese.
- Migração Gradativa Transparente: Militares com senhas antigas em texto têm o hash gerado automaticamente no instante do login sem qualquer falha ou necessidade de redefinição forçada.
- Audit Trail: Registro detalhado de cada evento em public.login_attempts.

3.3. Proteção Ativa contra Ataques de Dicionário e Força Bruta (Brute Force)

Implementação de Rate Limiting rígido com política de bloqueio temporário:

- Janela de Análise: 15 minutos móveis por identificador de usuário.
- Tolerância Máxima: 5 falhas consecutivas.
- Ação ao Estourar Limite: Acesso bloqueado (status: LOCKED) rejeitando novas tentativas até o fim da janela.
- Aviso Preventivo: O usuário recebe avisos visuais quando restam apenas 2 tentativas válidas.

3.4. Controle de Acesso e Prevenção de Escalada de Privilégios (RBAC)

A estrutura de permissões opera sob o princípio do menor privilégio (PoLP):

- Separação estrita entre ADMIN_TOTAL (acesso global entre OMs) e ADMIN_OM (restrito à sua unidade).
- Auto-escalada bloqueada: Militares não podem alterar seus próprios níveis de acesso nem perfis.
- Proteção de Escopo: Administradores de OM não podem conceder credenciais ADMIN_TOTAL a nenhum perfil.

4. Checklist de Conformidade Técnica para o Pentest

OWASP Top 10 - A01:2021 (Broken Access Control)	CONFORME (RBAC e RLS ativos)
OWASP Top 10 - A02:2021 (Cryptographic Failures)	CONFORME (Bcrypt 10 rounds)
OWASP Top 10 - A03:2021 (Injection / SQLi)	CONFORME (Consultas parametrizadas Supabase)
OWASP Top 10 - A04:2021 (Insecure Design)	CONFORME (Rate limit + auditoria de falhas)
OWASP Top 10 - A07:2021 (Identification & Auth Failures)	CONFORME (RPC segura e bloqueio)

5. Parecer Técnico de Conclusão

O aplicativo Guardião atingiu uma postura de segurança robusta e defensiva, mitigando com sucesso os principais achados críticos apontados nos ensaios prévios de vulnerabilidade. A estratégia de auto-upgrade e funções RPC permitiu elevar o nível de blindagem em produção sem gerar qualquer indisponibilidade (zero downtime) ou impacto na rotina dos operadores e sentinelas da organização militar. A aplicação encontra-se tecnicamente apta para submissão aos testes de intrusão formais (Pentest).

EQUIPE DE DESENVOLVIMENTO E ENGENHARIA DE SEGURANÇA

Sistema Guardião — Grupo de Segurança e Defesa (GSD-SP)